

3.4 Module Quiz

Date: 3/15/2026, 9:19:03 PM

Time Spent: 11:30

Score: 100%

Passing Score: 80%

Question 1

✓ Correct

What is one potential benefit of using prompt compression in environments where AI system usage is charged by token usage?

- ☐ It guarantees all system responses are more accurate
- ☒ It reduces the number of tokens required, helping to control operational costs ✓ Correct
- ☐ It ensures all user prompts are fully encrypted for privacy
- ☐ It eliminates the need for logging or monitoring AI inputs

Explanation

It reduces the number of tokens required, helping to control operational costs is the correct answer. Since many AI platforms charge based on tokens, prompt compression directly helps to lower the overall cost by using fewer tokens.

It guarantees all system responses are more accurate is incorrect. Prompt compression does not guarantee accuracy, although it can help responses be more direct.

It ensures all user prompts are fully encrypted for privacy is incorrect. Compression is not a form of encryption for privacy; these are separate processes.

It eliminates the need for logging or monitoring AI inputs is incorrect. Logging and monitoring remain necessary regardless of prompt compression strategies.

Related Content



3.3.2 Performance and Cost Monitoring

resources\questions\q_performance_and_cost_monitoring_03.question.xml

A cloud services company is deploying an AI analytics tool that will be accessed by data scientists, business analysts, and system administrators. Each group requires access to different AI model features and datasets based on their job functions.

After confirming user identities through secure login, the IT team needs to ensure each group can only interact with the parts of the platform necessary for their job roles.

Which of the following actions BEST demonstrates the application of the "authorization" process in identity and access management (IAM) for this scenario?

- ☐ Requiring each user to register for a unique account before being allowed any access to the AI environment, ensuring identification is unique and traceable.
- ☒ Configuring the system so that data scientists can access advanced model training features, business analysts can only generate reports, and system administrators have full control over all resources. ✔ Correct
- ☐ Logging every user's activity in the analytics tool to detect any unauthorized actions or suspicious behaviors, with periodic reviews.
- ☐ Setting up multi-factor authentication for all users accessing the AI analytics tool.

Explanation

Configuring the system so data scientists access advanced features, business analysts generate reports, and system administrators have full control is correct. This is authorization—assigning and enforcing permissions by role, controlling what authenticated users can do.

Setting up multi-factor authentication for users is incorrect. This addresses authentication, verifying user identity with multiple credentials, but does not govern what resources or actions users can access.

Logging user activity and periodically reviewing for suspicious behavior is incorrect. This is accounting (auditing), which involves monitoring and tracking user actions, not setting or enforcing access rights.

Requiring each user to register for a unique account is incorrect. This is identification, establishing digital identities, not controlling access to resources. Authorization occurs after identification and authentication.

Related Content

 3.1.1 Access Control Principles for AI

 3.1.5 Model Access

resources\questions\q_access_control_principles_for_ai_05.question.xml

Question 3

✓ Correct

Which of the following technologies is specifically designed to help protect data while it is being actively processed or used by an AI system?

- ☐ Secure Sockets Layer (SSL)
- ☐ Data classification labeling (such as "Confidential" or "Top Secret")
- ☒ Trusted Execution Environment (TEE) ✓ Correct
- ☐ File-level encryption

Explanation

Trusted Execution Environment (TEE) is correct. A TEE is a secure processor area that protects data while it is actively being processed ("in use"), keeping sensitive data isolated from the rest of the system.

File-level encryption is incorrect. It secures data at rest but does not protect it during processing.

Secure Sockets Layer (SSL) is incorrect. SSL encrypts data in transit, not during CPU or AI system processing.

Data classification labeling (such as "Confidential" or "Top Secret") is incorrect. Labels indicate data sensitivity and handling requirements, but do not themselves protect or encrypt data in use. Actual protection during processing requires approaches like TEE.

Related Content

 3.2.2 Encryption of AI Data

resources\questions\q_encryption_of_data_05.question.xml

What is the primary benefit of encrypting data in transit in AI systems?

- ☒ It prevents unauthorized interception and reading of sensitive data sent over a network. ✓ Correct
- ☐ It anonymizes all user data before any processing occurs.
- ☐ It increases the computational speed of the AI system when handling user requests.
- ☐ It protects data from being modified while stored on a physical hard drive.

Explanation

It prevents unauthorized interception and reading of sensitive data sent over a network is the correct answer. Encrypting data in transit ensures that sensitive information traveling between endpoints (such as between an AI system and a user) cannot be intercepted and read by unauthorized parties.

It protects data from being modified while stored on a physical hard drive is incorrect. This describes the protection of data at rest, not data in transit.

It anonymizes all user data before any processing occurs is incorrect. Encryption in transit does not anonymize user data; it only protects its confidentiality while moving between systems.

It increases the computational speed of the AI system when handling user requests is incorrect. Encryption generally adds some computational overhead rather than increasing computational speed.

Related Content



3.2.2 Encryption of AI Data

resources\questions\q_encryption_of_data_03.question.xml

A global healthcare organization uses ABAC in its AI system to manage access to sensitive patient data. Data is labeled as "public," "internal," or "restricted," and user accounts are tagged with attributes like department, clearance level, and location.

However, recent audits reveal that some attributes are outdated or missing—AI researchers at remote sites cannot access necessary internal datasets, while certain administrative staff in Europe have access to "restricted" U.S. patient records, which is a compliance issue.

Given the unresolved ABAC configuration, what action should the security team take to BEST address the access problems identified in the audit?

- ☒ Regularly review and update user and resource attributes to ensure they reflect current status, roles, and compliance requirements, then adjust ABAC policies to accurately grant or restrict access as appropriate. ✓ Correct
- ☐ Issue a policy reminding users to request access through IT if needed, but leave the attribute store as-is to avoid disrupting other users' existing access for now; prioritize convenience over immediate correction.
- ☐ Increase physical security controls at all healthcare sites and disable the sharing functions in the AI system, assuming that stricter physical safeguards will compensate for potential attribute errors in digital access.
- ☐ Restrict all data labeled "restricted" so no user can access it, regardless of attributes, until a new ABAC solution is implemented; resume access when the system is fully re-engineered.

Explanation

Regularly reviewing and updating user and resource attributes, then adjusting ABAC policies to match current roles, compliance, and status, is correct. This directly addresses ABAC issues by ensuring access is properly granted or restricted based on accurate, up-to-date attributes.

Restricting all "restricted" data to everyone until a new ABAC system is deployed is incorrect. This overrestricts access, disrupts business and research, and is inefficient and impractical.

Telling users to request access through IT while leaving outdated attributes is incorrect. This creates a manual, error-prone process and fails to resolve ABAC issues, risking ongoing compliance problems.

Increasing physical security and disabling digital sharing is incorrect. These steps do not fix attribute misconfigurations in access controls and reduce the system's utility without solving the real problem.

Related Content



3.1.2 AI Access Control Models



3.1.8 Network and API Access

resources\questions\q_ai_access_control_models_02.question.xml

Your organization is developing a cloud-based AI application that processes and stores sensitive customer information, including personal identifiers.

As a security measure, you are considering how to protect this data while it is stored on the cloud server but not being actively used or transmitted.

Which of the following solutions should you implement to BEST address this requirement?

- ☐ Implement HTTPS to secure communications between users and the AI application, and require strong passwords for system login.
- ☒ Use a file-level encryption tool and store encryption keys in a cloud Key Management Service (KMS). ✓ Correct
- ☐ Apply data masking techniques when the data is requested by users, and rely on operating system access controls for storage protection.
- ☐ Enable multi-factor authentication (MFA) for all user accounts and regularly monitor access logs to detect suspicious activity, in addition to training staff on proper data handling procedures.

Explanation

Using a file-level encryption tool and storing encryption keys in a cloud Key Management Service (KMS) is correct. This encrypts stored data and secures keys, ensuring that data remains unreadable without proper authorization, even if storage is accessed.

Implementing HTTPS and requiring strong passwords is incorrect. HTTPS protects data in transit, not at rest, and strong passwords secure logins but do not encrypt stored files.

Applying data masking on user requests and relying on OS access controls is incorrect. Data masking is for display or processing, not storage. OS access controls alone are insufficient protection if the system is compromised; encryption is stronger.

Enabling multi-factor authentication, monitoring logs, and training staff is incorrect. These improve access security and awareness but do not encrypt data at rest.

Related Content



3.2.2 Encryption of AI Data

resources\questions\q_encryption_of_data_02.question.xml

Question 7

✓ Correct

In an AI project, when is data redaction typically applied as opposed to data minimization?

- ☐ Before data is collected, to choose which fields are mandatory.
- ☐ When designing data input forms to require only essential fields based on business needs and regulatory requirements.
- ☐ When restricting access to data based on user roles.
- ☒ After the data is collected, to obscure or remove sensitive elements that are not needed. ✓ Correct

Explanation

After the data is collected, obscuring or removing sensitive elements that are not needed is correct. Redaction means modifying or removing unnecessary sensitive data after collection to protect privacy.

Designing data input forms to require only essential fields is incorrect. This is data minimization, aiming to limit what is collected, not redaction.

Restricting access to data based on user roles is incorrect. This is role-based access control, which manages permissions, not data redaction.

Choosing mandatory fields before data is collected is incorrect. This is another example of data minimization—limiting collected data from the start, not removing it after collection as in redaction.

Related Content



3.2.3 Data Safety Measures

resources\questions\q_data_safety_measures_09.question.xml

A company has deployed an AI system that processes thousands of customer queries daily. Recently, users have reported increased response times and inconsistent output quality, especially during peak hours.

As the system administrator, you are tasked with improving the system's performance and ensuring cost-effectiveness.

Which of the following adjustments should you prioritize based on best performance monitoring practices described in the reading?

- ☐ Limit access to system logs by setting them to read-only
- ☐ Only audit for hallucinations in the AI system
- ☐ Mask personally identifiable information (PII) in stored prompts
- ☒ Increase hardware resources during peak usage times ✓ Correct

Explanation

Increase hardware resources during peak usage times is the correct answer. Performance monitoring includes tracking query and response rates to identify peak usage times. Increasing hardware resources during those times directly addresses slow response and degraded output quality, aligning with best practices for optimized operation and ensuring the system can handle peak workloads efficiently.

Limit access to system logs by setting them to read-only is incorrect. Limiting access to logs by setting them to read-only is a measure designed for protecting log integrity, not for improving live system performance or responsiveness during peaks.

Only audit for hallucinations in the AI system is incorrect. Auditing for hallucinations is a quality and compliance activity. While important, it doesn't address the immediate performance issues of slow response time and workload management.

Mask personally identifiable information (PII) in stored prompts is incorrect. Masking PII in stored prompts is a crucial log sanitization process for data privacy, but it does not impact the AI system's capacity to process queries or improve performance during peak hours.

Related Content

 3.3.2 Performance and Cost Monitoring

Question 9

✓ Correct

Your organization's AI system is experiencing heavy usage, with frequent slowdowns during peak hours. Based on the information provided in your monitoring and auditing reports, you are tasked with optimizing the performance of the system to better support the workload.

Which of the following actions BEST applies to managing heavily used systems?

- ☐ Delete older user logs and prompts immediately after each session to free up system memory for processing current interactions.
- ☒ Upgrade the system's CPU, GPU, and storage hardware to improve processing speed and capacity, reducing latency during peak hours. ✓ Correct
- ☐ Restrict user access to the AI system by setting strict quotas on the number of permitted daily queries per user, regardless of business needs.
- ☐ Schedule system downtime during peak hours to prevent overload and ensure the AI system is not overused.

Explanation

Upgrading the system's CPU, GPU, and storage hardware to improve processing speed and capacity, reducing latency during peak hours is the correct answer. Upgrading hardware directly addresses the performance bottleneck caused by heavy use. By increasing CPU, GPU, and storage resources, the system can handle higher workloads more efficiently with reduced latency, as recommended for heavily used systems.

Scheduling system downtime during peak hours to prevent overload and ensure the AI system is not overused is incorrect. Scheduling downtime during peak hours disrupts productivity and frustrates users when the system is needed most. This approach does not solve the underlying performance issue and results in decreased business effectiveness.

Deleting older user logs and prompts immediately after each session to free up system memory for processing current interactions is incorrect. Deleting older user logs and prompts immediately after each session might temporarily free up some memory but sacrifices valuable audit and monitoring data, potentially impacting compliance and the ability to analyze system trends. This reactive approach does not address the system's ability to scale and process high workloads, and may also lead to data loss that could hinder investigations or future improvements.

Restricting user access to the AI system by setting strict quotas on the number of permitted daily queries per user, regardless of business needs, is incorrect. Strictly limiting user queries can help manage system load but will likely reduce user satisfaction and productivity. It does not optimize system performance or support legitimate business needs during high-demand periods, making it a less effective solution.

Related Content



3.3.2 Performance and Cost Monitoring

resources\questions\q_performance_and_cost_monitoring_07.question.xml

A company deploys a customer support AI chatbot using a large language model (LLM). After deployment, a malicious user submits inputs specifically designed to bypass intended restrictions, leading the chatbot to disclose confidential company procedures and customer data.

The company's security team identifies this as a critical issue from the OWASP Top 10 for LLM Applications.

Which specific type of OWASP AI threat has the attacker exploited in this situation?

- ☐ Excessive Agency
- ☐ Data Poisoning
- ☐ Model Theft
- ☒ Prompt Injection ✓ Correct

Explanation

Prompt injection is correct. It's an OWASP Top 10 threat for LLM applications and occurs when crafted prompts trick a language model into revealing sensitive data or ignoring safeguards, as seen in this scenario.

Model theft is incorrect. This involves stealing or copying the AI model itself. Here, the attacker manipulated outputs, not the model.

Data poisoning is incorrect. It corrupts training data to affect future outputs. In this case, the attack happened through user prompts in real-time, not via training data.

Excessive agency is incorrect. This refers to a model taking actions beyond its intended scope. Here, the issue was prompt manipulation—not the chatbot acting with excessive autonomy.

Related Content

 3.1.4 Threat Landscape of AI Systems

 3.1.7 Data and Agent Access

resources\questions\q_threat_landscape_of_ai_systems_03.question.xml

Which of the following tools or services is commonly used to manage encryption keys for data at rest in cloud-based AI systems?

☒ Key Management Service (KMS) ✓ Correct

☐ Secure File Transfer Protocol (SFTP)

☐ Hypertext Transfer Protocol Secure (HTTPS)

☐ Data Redaction Tool

Explanation

Key Management Service (KMS) is the correct answer. Key Management Services (KMS), such as AWS KMS or Azure Key Vault, are specifically designed to secure the storage and management of encryption keys for encrypted data at rest.

Secure File Transfer Protocol (SFTP) is incorrect. SFTP provides encrypted file transfer, which is relevant to data in transit, not the management of encryption keys for data at rest.

Hypertext Transfer Protocol Secure (HTTPS) is incorrect. HTTPS secures data while in transit between client and server, not while it is stored (at rest).

Data Redaction Tool is incorrect. Data redaction removes or obscures sensitive information from datasets, but it does not manage encryption keys or deal with the encryption of stored data.

Related Content



3.2.2 Encryption of AI Data

resources\questions\q_encryption_of_data_01.question.xml

A healthcare startup is rolling out an AI-driven application that handles sensitive patient questions and retrieves medical information. The organization must comply with strict regulatory programs related to data privacy and access.

To ensure prompt and log monitoring adheres to these regulations, what should the organization's IT security team do as part of its implementation?

- ☐ Focus exclusively on monitoring prompt performance metrics, such as response times and user query counts, rather than on data privacy or access control compliance for logs.
- ☐ Retain all raw logs, including unredacted personal health information, for as long as possible to help with future audits and improve the AI system's models.
- ☐ Only log successful AI responses that do not contain patient data, since compliance programs do not require documentation of access details for non-sensitive interactions.
- ☒ Ensure all logs are sanitized to remove or mask sensitive data, apply access controls to log files, and maintain detailed audit records as required by regulatory compliance programs.

✔ Correct

Explanation

Ensuring all logs are sanitized to remove or mask sensitive data, applying access controls to log files, and maintaining detailed audit records as required by regulatory compliance programs is the correct answer. This answer correctly applies the requirements regarding regulatory compliance and log monitoring in sensitive environments like healthcare. Regulatory programs (such as HIPAA) demand that sensitive data (like PHI/PII) be sanitized or masked in logs, that access to logs is tightly controlled, and that complete audit trails are maintained for review. This approach ensures the organization protects privacy and follows legal standards.

Only logging successful AI responses that do not contain patient data, since compliance programs do not require documentation of access details for non-sensitive interactions, is incorrect. This is not sufficient for regulatory compliance. Regulations often require documentation of all access attempts, successful or not, and complete audit trails regardless of the presence of sensitive content. This answer could leave the organization non-compliant and unprotected against certain access violations.

Focusing exclusively on monitoring prompt performance metrics, such as response times and user query counts is incorrect. Focusing solely on performance metrics ignores regulatory requirements around privacy, access, and log protection. Compliance programs place significant emphasis on how sensitive data is handled and logged, so non-compliance could result from not addressing privacy and access control in the monitoring process.

Retaining all raw logs, including unredacted personal health information, for as long as possible to help with future audits and improve the AI system's models, is incorrect. This poses significant privacy and legal risks. Regulatory compliance programs require protection, minimization, and in many cases, scheduled deletion or redaction of sensitive data to prevent unauthorized access or data breaches. This likely violates major privacy laws such as HIPAA or GDPR. Improving models with raw sensitive data does not justify disregarding compliance requirements.

Related Content



3.3.1 Prompt and Log Monitoring

resources\questions\q_prompt_and_log_monitoring_08.question.xml

What is the primary purpose of the identification process in Identity and Access Management (IAM) for AI systems?

- ☐ To track and log user activity for later review and auditing.
- ☐ To prove the credentials of a user before accessing a resource.
- ☐ To determine what actions a user is allowed to perform on specific resources.
- ☒ To create an account or identity that uniquely represents the user, device, or process. ✓ Correct

Explanation

To create an account or identity that uniquely represents the user, device, or process is the correct answer. Identification is the process of establishing a unique identity for each user, device, or process.

To determine what actions a user is allowed to perform on specific resources is incorrect. This describes authorization, which decides user permissions for resources.

To prove the credentials of a user before accessing a resource is incorrect. This is the role of authentication, which involves validating a subject's credentials.

To track and log user activity for later review and auditing is incorrect. This describes accounting, not identification. Accounting involves logging and monitoring access.

Related Content

 3.1.1 Access Control Principles for AI

 3.1.5 Model Access

resources\questions\q_access_control_principles_for_ai_02.question.xml

Your organization's AI-driven analytics platform receives large volumes of sensitive data from customers via APIs. Recently, security audits uncovered log entries showing repeated failed API access attempts from unfamiliar IP addresses, as well as occasional unvalidated data being processed by the AI system.

As a security analyst, you must identify the weaknesses in the current network and API controls and recommend improvements based on the situation.

Which analysis BEST identifies the key weaknesses and recommends targeted improvements?

- ☐ The failed access attempts are normal and do not suggest any pressing need for changes, as failed logins show the system is effectively stopping attackers; leaving existing controls in place is adequate, possibly with a periodic log review.

- ☒ The lack of IP allow-listing, insufficient authentication mechanisms, and failure to validate input data are enabling unauthorized and potentially malicious access; enhancements should include implementing IP access controls, strong multi-factor authentication, and OAuth tokens for API access. ✓ Correct

- ☐ The main issue is the volume of incoming data overwhelming the system, so configuring API throttling and rate limiting is sufficient to resolve both unauthorized access and input validation failures.

- ☐ The probable issue is with the speed of API responses—slow authentication is causing repeated failures; upgrading the network infrastructure and minimizing user authentication steps will likely resolve both failed logins and unvalidated data errors.

Explanation

The correct answer is that the lack of IP allow-listing, weak authentication, and missing input validation enable unauthorized, potentially malicious access. Improvements should include IP access controls, multi-factor authentication, OAuth tokens for API access, strict input validation, and logging. These address root issues highlighted by failed access attempts and unvalidated data.

Configuring API throttling alone is incorrect. Throttling helps manage high traffic but does not prevent unauthorized access or fix input validation issues.

Assuming failed login attempts are normal and not updating controls is incorrect. Persistent failed logins can signify attacks and require enhanced controls—not just periodic log reviews.

Reducing authentication steps to speed up logins is incorrect. This weakens security and ignores the need for robust authentication and input validation.

Related Content



3.1.2 AI Access Control Models



3.1.8 Network and API Access

resources\questions\q_network_and_api_accerss_04._question.question.xml

A financial institution is auditing its AI-powered loan recommendation system for bias and fairness as part of its regular quality and compliance checks.

The audit team decides to use a method where they alter certain input attributes, such as changing the applicant's occupation or location, and observe if the AI's recommendation changes without justification by the altered attribute.

Which testing approach is the audit team applying, and why is it helpful in this context?

- ☒ Counterfactual testing, because it reveals if changes to input attributes result in unjustified or biased changes in output, thus uncovering hidden bias in recommendations. ✓ Correct
- ☐ Latency monitoring, because it helps identify the cause of recommendation delays when input fields are modified, pinpointing possible bias in processing speed.
- ☐ BLEU evaluation, because it focuses on whether the language in the AI recommendation closely matches a human-generated reference without considering input changes.
- ☐ Hallucination detection, because it evaluates whether the AI system produces fictional or implausible loan recommendations based on the input data.

Explanation

Counterfactual testing, because it reveals if changes to input attributes result in unjustified or biased changes in output, thus uncovering hidden bias in recommendations is the correct answer. Counterfactual testing is specifically used to analyze how AI system outputs vary when certain input features are changed. By observing these changes, auditors can identify if the AI model makes biased or unfair decisions based on specific attributes. This approach is crucial for ensuring fairness and compliance in systems affecting individuals' opportunities.

Hallucination detection, because it evaluates whether the AI system produces fictional or implausible loan recommendations based on the input data is incorrect. Hallucination detection is a technique intended to identify when an AI model outputs information that is not grounded in the input data or known facts. It cannot reliably uncover bias.

BLEU evaluation, because it focuses on whether the language in the AI recommendation closely matches a human-generated reference without considering input changes is incorrect. BLEU is designed to measure how closely a machine-generated response matches a set of reference texts. It does not assess bias or fairness through input manipulation. It evaluates text similarity, not system behavior across changing inputs.

Latency monitoring, because it helps identify the cause of recommendation delays when input fields are modified, pinpointing possible bias in processing speed is incorrect. Latency monitoring is used to measure system performance by tracking response delays after input is submitted. It does not address fairness, bias, or the impact of specific input changes on the model's decision-making, so it cannot provide insight into compliance or ethical issues in the recommendations.

Related Content



3.3.4 Quality and Compliance Auditing

resources\questions\q_quality_and_compliance_auditing_08.question.xml